Security is paramount in any cloud environment, especially within a powerful platform like GKE. This section focuses on the critical aspects of security within your GKE ecosystem. Compliance requirements are constantly evolving, and maintaining a robust security posture is essential. We'll examine how to implement preventative controls to mitigate potential threats before they materialize. Prepare to learn how to proactively secure your containerized applications.

Proprietary + Confidential

Security Posture, Compliance, and Preventative Controls

01 GKE security posture overview

02 Security posture dashboard

03 Implementing node security

04 Vulnerability scanning

05 Additional security services

Google Cloud

In this section, titled Security posture, compliance, and preventative controls, you learn to:

- Describe GKE security posture.
- Navigate and interpret the GKE security posture dashboard to identify security issues.
- Implement node security measures to protect GKE worker nodes from potential threats.
- Describe the process of vulnerability scanning in GKE.
- Explain the roles and capabilities of Google Cloud's Artifact Analysis and Security Command Center in enhancing GKE security.

Proprietary + Confidential

Security Posture, Compliance, and Preventative Controls

01 GKE security posture overview

02 Security posture dashboard

03 Implementing node security

04 Vulnerability scanning

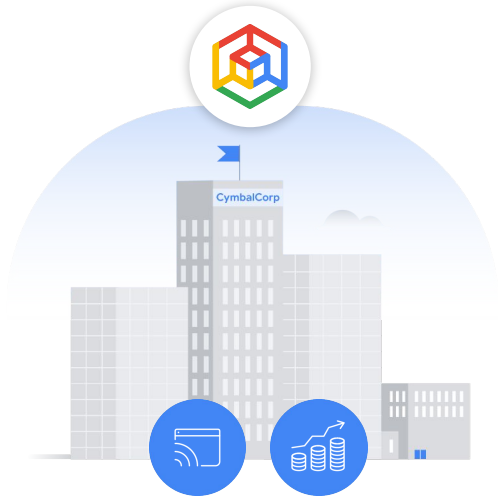
05 Additional security services

Google Cloud

GKE security posture refers to the overall security, health and resilience of your GKE environment.

Proprietary + Confidential

CymbalCorp use case



CymbalCorp must effectively protect their clusters, workloads, and data from threats.

Google Cloud

Imagine "CymbalCorp," a large, sprawling organization leveraging GKE. They host everything from customer-facing web applications to sensitive financial processing systems. This variety requires diverse workloads with vastly different security needs. A one-size-fits-all approach simply won't cut it. This is where the robust security posture of GKE comes in.

It's necessary that organizations like CymbalCorp effectively protect their clusters, workloads, and data from threats.

Proprietary + Confidential

A strong GKE security posture is a multi-layered approach

Google Cloud

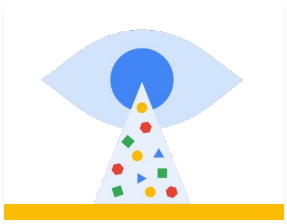
A strong GKE security posture is a multi-layered approach. It encompasses the policies, configurations, and practices implemented to protect your clusters, workloads, and data from potential threats and vulnerabilities.

Proprietary + Confidential

Introduction to security posture

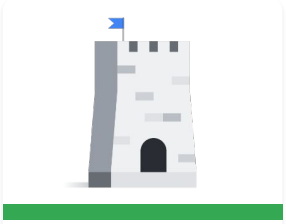
Shared responsibility

Google secures the underlying infrastructure, you secure the applications and data within that infrastructure.



Visibility and monitoring

The GKE Security Posture Dashboard provides a centralized view of your security health.



Control plane hardening

Ensure the core of Kubernetes clusters are fortified through RBAC, network security policies, and continuous updates.

Node security

Safeguard the worker nodes where workloads run, including Container-Optimized OS, Shielded Nodes for integrity, and automated updates for vulnerability patching.

Google Cloud

Security posture spans the entire container lifecycle and includes several key areas:

Shared responsibility: Google secures the underlying infrastructure while you secure the applications and data *within* that infrastructure. This clarity of responsibility is the foundation.

Visibility and monitoring: The GKE security posture dashboard provides a centralized view of your security health, enabling you to proactively detect and respond to threats.

Control plane hardening: Ensure the core of Kubernetes clusters are fortified through RBAC, network security policies, and continuous updates.

Node security: Safeguard the worker nodes where workloads run, including Container-Optimized OS, Shielded Nodes for integrity, and automated updates for vulnerability patching.

Proprietary + Confidential

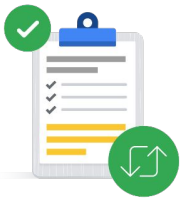
Introduction to security posture

Image security

Use vulnerability scanning, binary authorization, and secure image registries to manage container images.

Network security

Network policies, firewalls, and private clusters can be used to control traffic flow and isolate workloads.



Continuous compliance

Tools and processes are used to ensure adherence to industry regulations and internal security policies.

Google Cloud

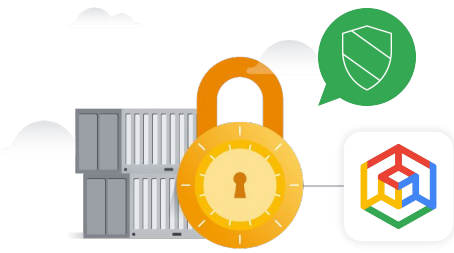
Image security: The container images that power applications must be managed. This is achieved through vulnerability scanning, Binary Authorization to enforce policies, and secure image registries.

Network security: Network policies, firewalls, and private clusters can be used to control traffic flow and isolate workloads.

Continuous compliance: Tools and processes are used to ensure adherence to industry regulations and internal security policies.

Proprietary + Confidential

Security posture goals



- Minimize the attack surface
- Prevent unauthorized access
- Detect and respond to threats
- Ensure compliance

Google Cloud

Ultimately, a robust GKE security posture aims to:

- **Minimize the attack surface:** Reduce potential vulnerabilities and entry points for attackers.
- **Prevent unauthorized access:** Control access to your clusters and resources based on the principle of least privilege.
- **Detect and respond to threats:** Identify and mitigate security incidents promptly.
- **Ensure compliance:** Meet regulatory and organizational security requirements.

Proprietary + Confidential

Enterprise-grade security posture

Google Kubernetes Engine

- Shared responsibility
- Node security
- Vulnerability scanning
- Comprehensive visibility
- Automated controls
- Advanced threat detection

Google Cloud

GKE has a strong foundation of security features, like shared responsibility, hardening, node security, and basic vulnerability scanning.

GKE builds upon this foundation to offer more comprehensive visibility, automated controls, and advanced threat detection. This addressed the diverse workloads and strict security requirements that enterprise level organizations encounter.

Proprietary + Confidential

Security Posture, Compliance, and Preventative Controls

01 GKE security posture overview

02 Security posture dashboard

03 Implementing node security

04 Vulnerability scanning

05 Additional Security Services

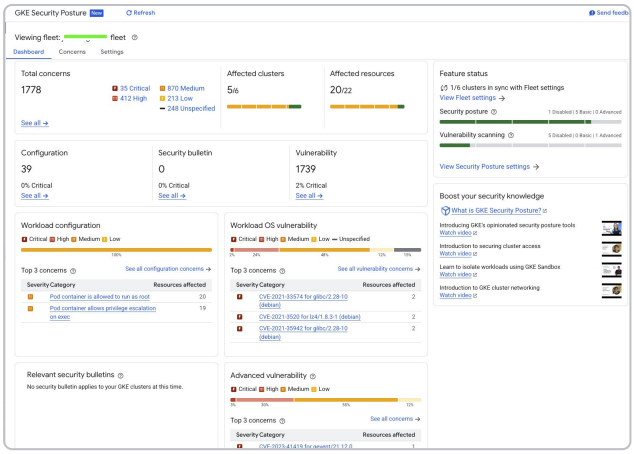
Google Cloud

The GKE security posture dashboard helps you monitor and maintain a strong security stance for your containerized workloads on GKE.

It provides a centralized, comprehensive view of the security health of your clusters, enabling you to identify and address potential risks.

Proprietary + Confidential

Security posture dashboard



- Centralized security view
- Configuration best practices
- Vulnerability scanning
- Actionable insights
- Continuous monitoring

Google Cloud

Let's explore the key features and benefits of the dashboard.

Centralized security view: The dashboard aggregates data from various sources, including Kubernetes audit logs, container image metadata, and vulnerability scans. This gives you a holistic understanding of your cluster's security status from a centralized location. Gone are the days of alternating between different tools to get the full picture.

Configuration best practices: The security posture dashboard compares your cluster configuration with GKE security best practice. These best practices cover role-based access control (RBAC), network policies, Pod Security Standards, and more. The dashboard even provides recommendations for improvements to enhance the security of your configuration.

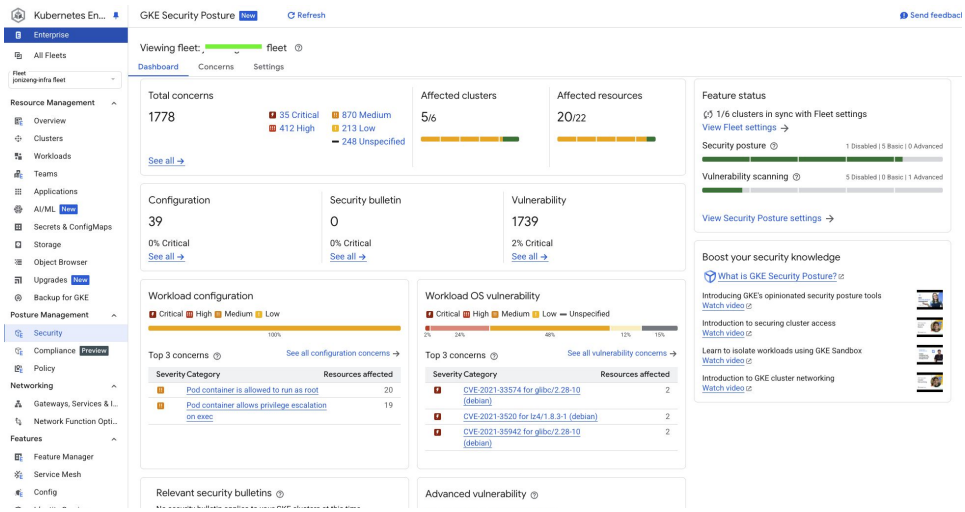
Vulnerability scanning: The dashboard integrates with Google Cloud Artifact Analysis to detect vulnerabilities in container images. It displays severity levels and provides mitigation advice, enabling you to prioritize and fix the most critical issues first.

Actionable insights: Actionable recommendations are given for security issues. These recommendations include links to documentation, configuration suggestions, and even command-line examples to help you address security concerns effectively.

Continuous monitoring: Security is constantly evolving. The dashboard continuously monitors your cluster and provides real-time updates on your security posture. This enables you to stay ahead of potential risks and maintain a strong security stance.

Proprietary + Confidential

Security posture dashboard organization



Google Cloud

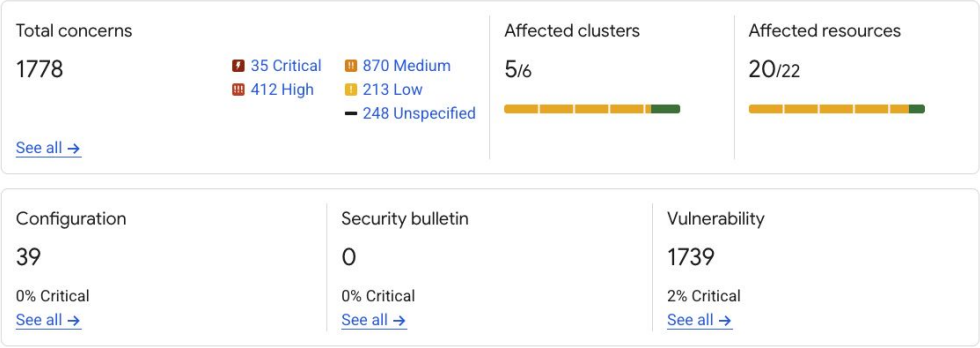
You can access the security posture dashboard through the Google Cloud console.

Navigate to the Kubernetes Engine section, select your cluster, and then choose **Security Posture** from the menu.

Let's transition and cover the dashboard's organization. The dashboard is divided into four main sections.

Proprietary + Confidential

The overview section

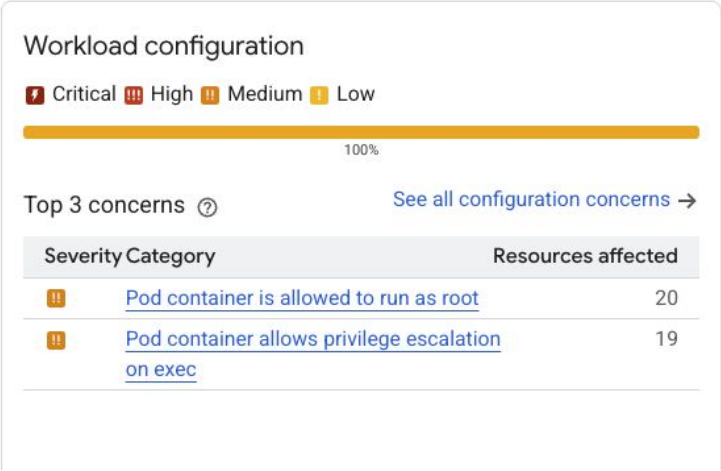


Google Cloud

The **overview** section provides a high-level summary of your cluster's security, including the amount and severity of security concerns.

Proprietary + Confidential

The Workload configuration section

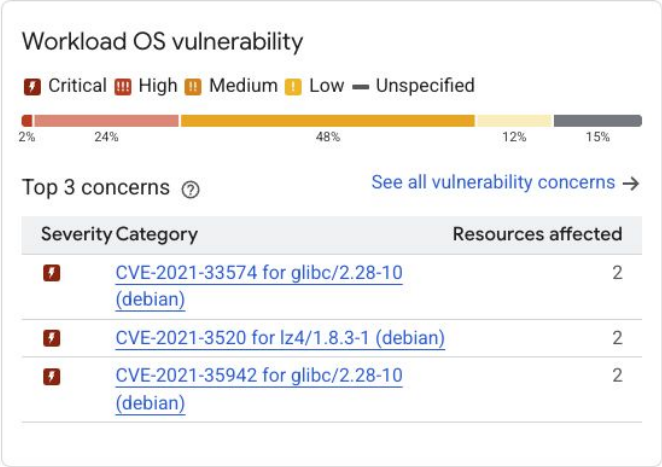


Google Cloud

In the **Workload configuration** section, cluster configuration is assessed and compared with GKE best practices. The dashboard also gives recommendations for security improvements.

Proprietary + Confidential

The Workload OS vulnerabilities section



Google Cloud

Container image vulnerabilities are exposed in the **Workload OS vulnerabilities** section along with remediation recommendations.

Finally, the threats section alerts you to potential threats detected by Google Cloud threat intelligence.

Proprietary + Confidential

Meet Sandra, a security engineer

Sandra

Security engineer

- Ensure platform infrastructure security by reviewing the dashboard to see current priority concerns.
- Take appropriate action based on recommended solutions.

Google Cloud

Let's explore an example of a common use case for the security posture dashboard. Meet Sandra, a security engineer. Sandra must ensure platform infrastructure security by reviewing the dashboard to see current priority concerns and take appropriate action based on recommended solutions.

Proprietary + Confidential

Issue: misconfigured pod securityContext

```
apiVersion: apps/v1
kind: Deployment
metadata:
  name: helloweb
  image:
us-docker.pkg.dev/google-samples/container
s/gke/hello-app:1.0
  ports:
  - containerPort: 8080
  securityContext:
    runAsNonRoot: false
  resources:
    requests:
      cpu: 200m
```

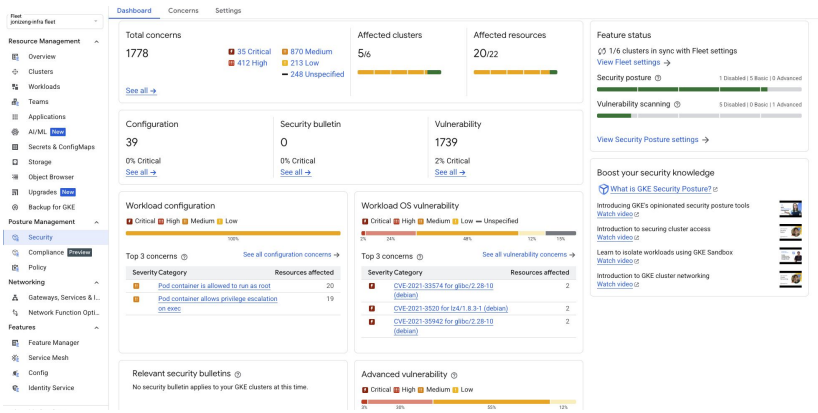
Does not adhere to security best practices

Google Cloud

A pod in Sandra's GKE environment is configured to not run as a non-root user, which is against security best practices.

Proprietary + Confidential

Sandra reviews the dashboard

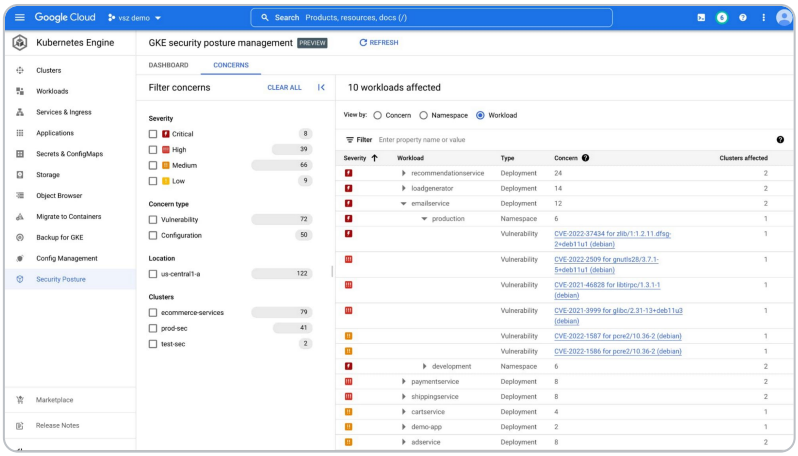


Google Cloud

Sandra reviews the dashboard and notices that this issue is flagged as a priority concern.

Proprietary + Confidential

Sandra examines concerns and their impact



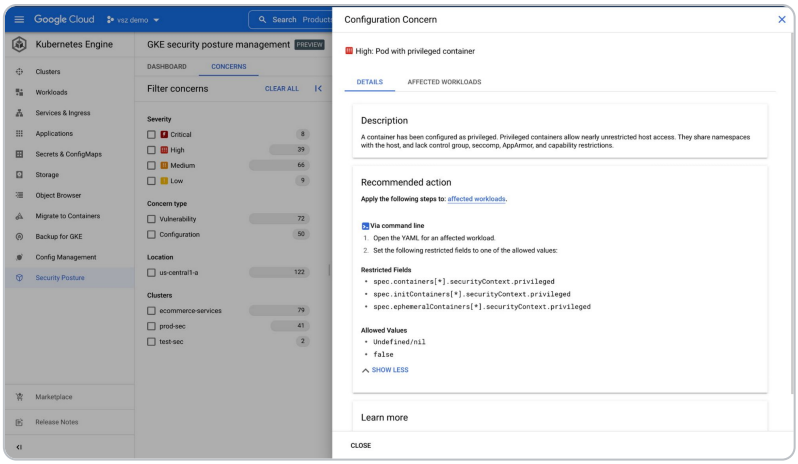
Google Cloud

Sandra clicks to drill into the issue and is provided with a breakdown of concerns and their impact.

She can view the data by location, cluster, or severity. Logical grouping is performed by Security Posture.

Proprietary + Confidential

Recommended solutions to issues and vulnerabilities



Google Cloud

The dashboard goes a step further and provides recommended solutions to common issues and vulnerabilities.

Proprietary + Confidential

Sandra quickly identifies and resolves the pod configuration issue

Sandra
Security engineer

Config management .yaml file

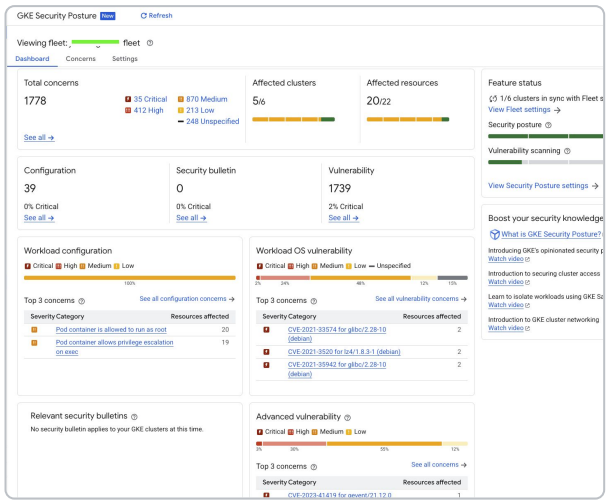
```
apiVersion: apps/v1
kind: Deployment
metadata:
  name: helloweb
  image:
us-docker.pkg.dev/google-samples/containers/gke/hello-app:1.0
  ports:
  - containerPort: 8080
  securityContext:
    runAsNonRoot: true
  resources:
    requests:
      cpu: 200m
```

Google Cloud

Equipped with insights and recommendations from the dashboard, Sandra quickly identifies and resolves the pod configuration issue.

Proprietary + Confidential

Security posture dashboard best practices



- Review the dashboard regularly to stay informed and address issues.
- Enable auto-remediation features to automatically address certain security concerns.
- Use the security posture dashboard in conjunction with other security tools.

Google Cloud

Let's review Google recommended practices for using the security posture dashboard.

Make it a practice to review the dashboard regularly to stay informed about your cluster's security status and to address any identified issues promptly.

Enable auto-remediation features to automatically address certain security concerns.

And use the security posture dashboard in conjunction with other security tools, such as Google Cloud Security Command Center and Binary Authorization, to enhance your overall security posture.

You explore these tools in detail in this section.

Proprietary + Confidential

Security Posture, Compliance, and Preventative Controls

01 GKE security posture overview

02 Security posture dashboard

03 Implementing node security

04 Vulnerability scanning

05 Additional security services

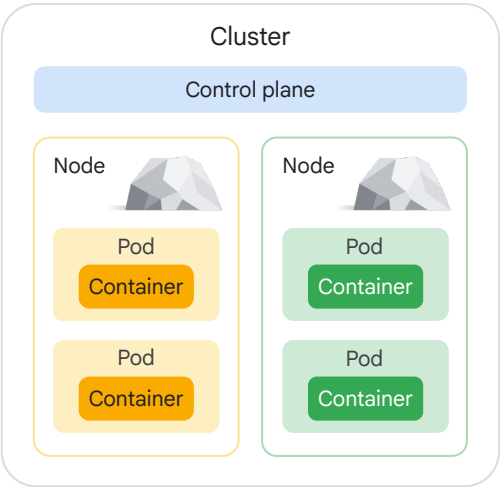
Google Cloud

Node security is the foundation of a secure GKE environment.

Because nodes host workloads, their integrity and protection directly correlates with the confidentiality, integrity, and availability of your applications.

Proprietary + Confidential

Reducing attack surface area by hardening nodes



- Distroless and scratch images contain only the software needed to run your applications, contributing to a smaller footprint.
- A Container-optimized OS (COS) is a hardened operating system for running containers.
- COS leverages a security-enhanced Linux kernel to restrict unauthorized access.

Google Cloud

Hardening nodes in a GKE cluster enhances security and reduces the attack surface of your containerized applications.

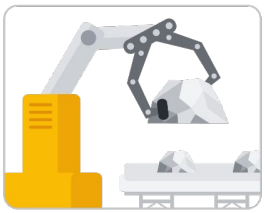
You can use "distroless" or "scratch" images that contain only the software needed to run your applications. This contributes to a smaller footprint, reducing potential vulnerabilities.

A Container-optimized OS (COS), is a hardened operating system specifically designed for running containers. COS offers a minimal attack surface, automatic security updates, and a secure boot process.

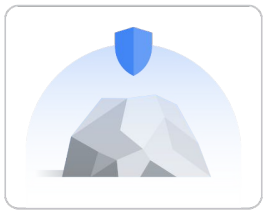
COS leverages a security-enhanced Linux kernel, providing mandatory access control and other security features to restrict unauthorized access.

Proprietary + Confidential

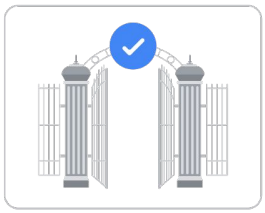
Methods for securing nodes



Auto-provisioning



Node shielding



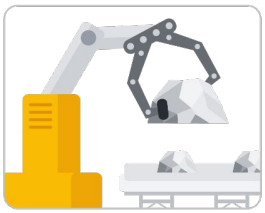
Binary authorization

Google Cloud

Methods for securing nodes include auto-provisioning, shielding, and binary authorization. Let’s explore each method in detail.

Proprietary + Confidential

Node auto-provisioning



Auto-provisioning

- Implement default security features like updates and firewalls.
- Automatic updates can be used to consistently patch nodes to minimize vulnerabilities.
- Auto-provisioning simplifies node management by automating tasks like scaling and repairs.

Google Cloud

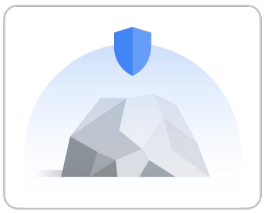
You can use node auto-provisioning to implement default security features like updates and firewalls.

Automatic updates can be used to consistently patch nodes to minimize vulnerabilities.

Auto-provisioning simplifies node management by automating tasks like scaling and repairs, so you can focus on other security aspects.

Proprietary + Confidential

Shielded nodes



Node shielding

- Designed to protect against rootkits, bootkits, and other low-level attacks.
- They use Secure Boot to verify the integrity of the boot process.
- Virtual Trusted Platform Modules (vTPM) establish a strong, verifiable node identity and ensure the integrity of the node's software and configuration.
- Runtime integrity monitoring detects and prevents malicious activity.

Google Cloud

Shielded nodes add an additional layer of security.

Shielded nodes are designed to protect against rootkits, bootkits, and other low-level attacks.

You can think of shielded nodes as fortified nodes that make it difficult for attackers to compromise.

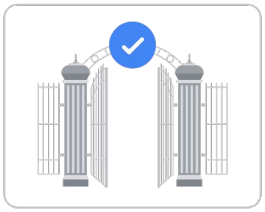
Shielded nodes use Secure Boot to verify the integrity of the boot process, ensuring that only trusted software is loaded. This prevents tampering and protects against malicious bootkits.

Virtual Trusted Platform Modules (vTPM) establish a strong, verifiable node identity and ensure the integrity of the node's software and configuration.

Runtime integrity monitoring detects and prevents malicious activity.

Proprietary + Confidential

Binary authorization



Binary authorization

- Ensures that only trusted container images are deployed within your clusters.
- Prevents the execution of unauthorized or potentially harmful images.
- The system checks if the image adheres to the established policies during deployment.
- If any checks fail, the deployment is blocked, preventing the execution of potentially dangerous code.

Google Cloud

Binary Authorization is also used to secure nodes.

Binary Authorization is like a gatekeeper. It ensures that only trusted container images are deployed within your clusters.

In essence, it prevents the execution of unauthorized or potentially harmful images, significantly enhancing the security and compliance of your containerized environment.

Proprietary + Confidential

Security Posture, Compliance, and Preventative Controls

01 GKE security posture overview

02 Security posture dashboard

03 Implementing node security

04 Vulnerability scanning

05 Additional security services

Google Cloud

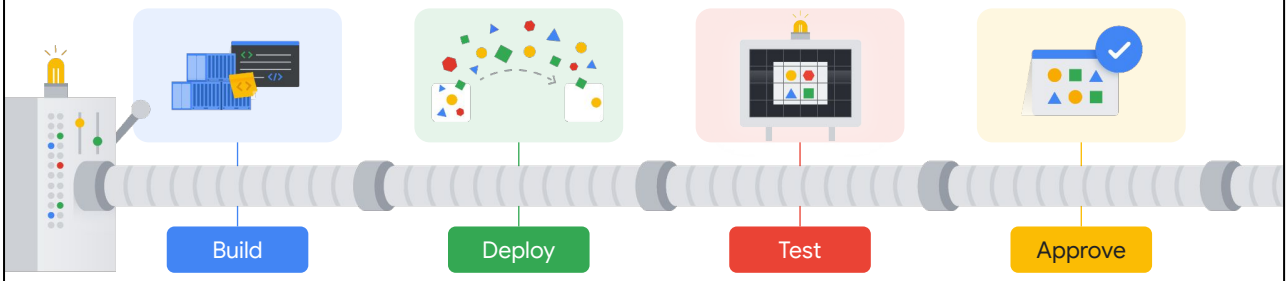
Vulnerability management is a critical aspect of maintaining a strong security posture in GKE.

It involves continuously identifying and addressing security weaknesses in your container images, operating systems, and application dependencies.

By proactively managing vulnerabilities, you can minimize the risk of exploitation and protect your workloads from potential threats.

Proprietary + Confidential

Vulnerability scanning is integrated into your CI/CD pipeline

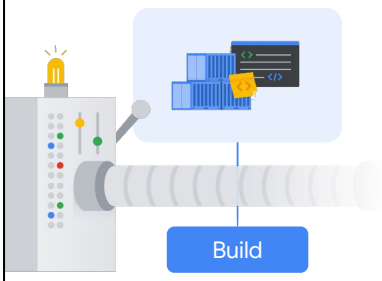


Google Cloud

Let's examine the vulnerability scanning process. Vulnerability scanning tools can be integrated into your CI/CD pipeline to identify vulnerabilities early in the development process. This allows you to address security issues before they reach production environments.

Proprietary + Confidential

The build phase



Immediately after the build, workload vulnerability scanning tools analyze the image. This includes OS package scanning and, with Advanced Vulnerability Insights (AVI), language package scanning.

Google Cloud

The first phase is the “build” phase. When developers commit code, the CI/CD pipeline builds the container image.

Immediately after the build, workload vulnerability scanning tools (like those leveraging Artifact Analysis) analyze the image. This includes OS package scanning and, with Advanced Vulnerability Insights (AVI), language package scanning.

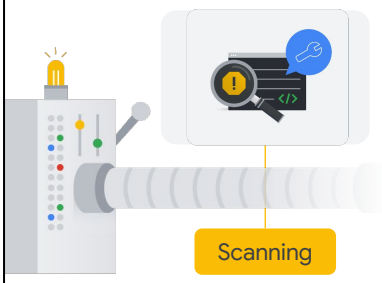
AVI extends GKE's vulnerability scanning capabilities to include language packages within your containerized applications.

It scans for known vulnerabilities in libraries and dependencies used by programming languages like Go, Maven, JavaScript, and Python.

Many vulnerabilities in runtime environments reside within these language packages, not just the underlying OS.

Proprietary + Confidential

The scanning phase



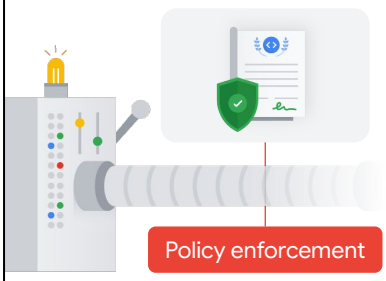
Tools integrated into the pipeline scan the OS and language-specific packages of application dependencies for vulnerabilities. These tools often leverage the Artifact Analysis feature.

Google Cloud

The next phase is scanning. Tools integrated into the pipeline scan the OS and language-specific packages of application dependencies for vulnerabilities. These tools often leverage the Artifact Analysis feature.

Proprietary + Confidential

Policy enforcement



Security policies can:

- Stop the build.
- Generate reports.
- Trigger automated remediation steps.

Google Cloud

After scanning has completed, the CI/CD pipeline can use security policies to:

- Stop the build if critical vulnerabilities are detected.
- Generate reports detailing vulnerabilities and their severity.
- Trigger automated remediation steps or create tickets for manual fixes.

If the image passes the security checks, it's stored in a container registry like Artifact Registry.

It is a recommended best practice to automate vulnerability scans to ensure regular and consistent checks for new vulnerabilities. This can be achieved through scheduled scans or by triggering scans on image updates.

Proprietary + Confidential

Security Posture, Compliance, and Preventative Controls

01 GKE Security Posture Overview

02 Security Posture Dashboard

03 Implementing Node Security

04 Vulnerability Scanning

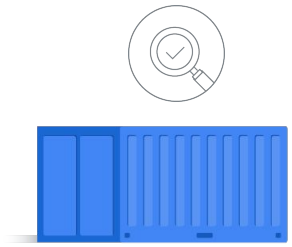
05 Additional Security Services

Google Cloud

Let's wrap up this section with an overview of Artifact Analysis and the Security Command Center.

Proprietary + Confidential

Artifact Analysis scans container images stored in Artifact Registry



- Detailed vulnerability scanning of container images stored in Artifact Registry.
- Provides insights into vulnerabilities within application dependencies and language-specific packages.
- Comprehensive vulnerability reports.
- Identify vulnerabilities before deployment.

Google Cloud

Artifact Analysis provides detailed vulnerability scanning of container images stored in Artifact Registry.

It goes beyond basic OS-level scanning, providing insights into vulnerabilities within application dependencies and language-specific packages (especially when combined with AVI).

When you push container images to Artifact Registry, Artifact Analysis automatically scans them.

This integration allows for continuous scanning of your container images, ensuring that you are always aware of potential vulnerabilities.

Artifact Analysis generates comprehensive vulnerability reports that include:

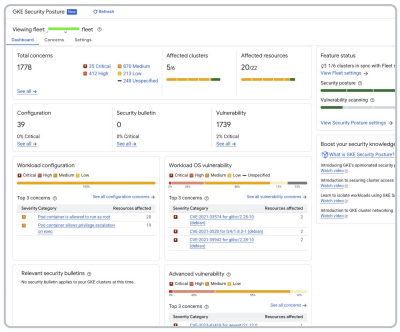
- CVE identifiers.
- Severity levels.
- Affected packages.
- Remediation recommendations.

It also helps identify vulnerabilities before container images are deployed to GKE clusters.

This is key within the CI/CD pipeline, as vulnerable images can be rejected before they become running workloads. This image data can be used by Binary Authorization to make decisions.

Proprietary + Confidential

Enhance GKE Security Posture with Security Command Center



Google Cloud

The security posture dashboard feeds vulnerability and configuration data into the Security Command Center, providing a unified and comprehensive view of your security posture.

Proprietary + Confidential

Security Command Center

- Provides a centralized view of security health across your entire Google Cloud environment.
- Aggregates security findings from various Google Cloud services.
- Identify vulnerabilities, configuration issues, compliance violations, and security gaps in your GKE environment.
- Runtime integrity monitoring detects and prevents malicious activity.

Google Cloud

Security Command Center provides a centralized view of security health across your entire Google Cloud environment, including GKE.

It aggregates security findings from various Google Cloud services, including Artifact Analysis, GKE Security Posture, and other security tools.

You can use the Security Command Center to identify vulnerabilities, configuration issues, compliance violations, and security gaps in your GKE environment.

Security Command Center has threat detection capabilities to help identify security incidents. And you can create security workflows and automations to rapidly respond to these events.